

CYBERSECURITY & ETHICAL HACKING

TASK 6 – COMPREHENSIVE PENETRATION TESTING REPORT & CAPSTONE

Enterprise-Style VAPT & Security Assessment Report

RabTech Academy — Cybersecurity Internship

Prepared by: Pritam Bose

Assessment basis: Tasks 2–5 | Authorized Training Environment

DOCUMENT STATUS: Final consolidated report draft

Evidence limitation note: Items not directly supported by supplied evidence are explicitly marked [NEW EVIDENCE REQUIRED].

1. Executive Summary

This capstone consolidates the authorized cybersecurity work completed across RabTech Academy Tasks 2–5. The material covers legal scope and threat modeling, network reconnaissance, web application vulnerability assessment, and practical cryptographic/security-control implementation.

The web application assessment demonstrated SQL Injection, DOM-based Cross-Site Scripting (XSS), and a broken object-level authorization condition consistent with BOLA/IDOR. These findings were validated in the controlled OWASP Juice Shop environment using browser and Burp Suite evidence.

The network reconnaissance work identified a broad exposed service surface on the deliberately vulnerable VM, including FTP, SSH, Telnet, SMTP, DNS, HTTP, SMB, MySQL, PostgreSQL, VNC and Tomcat. These observations establish attack-surface exposure but do not, by themselves, prove exploitation.

Task 5 demonstrated AES-256-GCM authenticated encryption, RSA-2048 key generation and digital-signature verification, and bcrypt password hashing using Node.js. These are treated as defensive controls rather than vulnerability findings.

Finding / Area	Assessment	Evidence	Priority
SQL Injection	Critical / 9.8*	Demonstrated	P1
BOLA / IDOR	High / 8.1*	Demonstrated	P1
DOM XSS	Medium / 6.1*	Demonstrated	P2
Exposed services	Attack-surface observation	Demonstrated	P2
LAB-02 scope reconciliation	Governance issue	Requires confirmation	P1

*CVSS values are preliminary analyst assessments for this capstone, not official vendor scores.

2. Scope, Authorization & Rules of Engagement

The Task 2 dossier defines the engagement as an authorized security lab exercise. Testing is restricted to assets explicitly included in the approved inventory; public Internet targets, third-party systems, unrelated VMs and other networks are outside scope unless explicitly approved.

Asset	Description	Authorized Scope	Key Restrictions
LAB-01	Local training web application	http://127.0.0.1:8080	No DoS / third-party scanning
LAB-02	Deliberately vulnerable VM	192.168.56.20	No persistence / outbound traffic

Rules Applied

- Testing remained within controlled training targets.
- No denial-of-service or destructive activity was performed.
- No persistence was attempted.
- No third-party systems were intentionally scanned.
- Evidence collection was limited to the minimum required for assessment and reporting.
- Secrets, credentials and unrelated personal information should not be exposed in evidence.

Scope / IP Reconciliation

The Task 2 authorization inventory identifies LAB-02 as 192.168.56.20, while earlier setup evidence recorded 192.168.56.128. The current Task 3 screenshots supplied for this final report target 192.168.56.20, matching the authorized inventory. The earlier discrepancy should still be formally confirmed in the engagement record rather than silently ignored.

3. Threat Model & Assessment Methodology

The Task 2 threat model uses STRIDE to identify relevant abuse cases and defensive priorities in the authorized lab.

STRIDE	Relevant Risk	Priority Mitigation
Spoofing	Unauthorized impersonation of a lab identity	Unique credentials; restrict authentication exposure
Tampering	Unauthorized modification of application/system data	Restrict write access; maintain clean snapshots
Repudiation	Poor attribution of actions	Preserve timestamps, commands and logs
Information Disclosure	Exposure of training data, credentials or evidence	Minimum collection; redact secrets
Denial of Service	Lab disruption from aggressive testing	No DoS testing; conservative rates
Elevation of Privilege	Privilege beyond testing account	Controlled validation; no persistence

Assessment Workflow

- Scope and authorization review
- Reconnaissance and service enumeration
- Web application mapping
- HTTP request/response analysis
- Manual vulnerability validation
- Security-control review
- Risk assessment and preliminary CVSS analysis
- Remediation planning and evidence consolidation

Tools Referenced

Kali Linux, Nmap, Wireshark, Burp Suite, browser tooling, Node.js and bcrypt were used across the completed tasks.

4. Network Reconnaissance & Attack Surface

Task 3 documents authorized reconnaissance of LAB-02 using Nmap and Wireshark. The supplied evidence identifies numerous open TCP services and multiple UDP services. These results describe exposure and should not be treated as proof of exploitation.

Port	Service / Version
21/tcp	FTP — vsftpd 2.3.4
22/tcp	SSH — OpenSSH 4.7p1
23/tcp	Telnet — Linux telnetd
25/tcp	SMTP — Postfix smtpd
53/tcp	DNS — ISC BIND 9.4.2
80/tcp	HTTP — Apache httpd 2.2.8
139, 445/tcp	SMB — Samba 3.X-4.X
3306/tcp	MySQL — 5.0.51a-3ubuntu5
5432/tcp	PostgreSQL — 8.3.0-8.3.7
5900/tcp	VNC — Protocol 3.3
8009/tcp	AJP13 — Apache Jserv
8180/tcp	HTTP — Apache Tomcat/Coyote JSP 1.1
53/UDP	DNS
111/UDP	rpcbind
137/UDP	NetBIOS-NS
2049/UDP	NFS

Security interpretation: legacy protocols and broad service exposure increase attack surface. Any remediation decision should be based on business need, patch status, segmentation and the lab's intended learning objective.

5. Network Evidence — Reachability & TCP SYN

The screenshots below are the current Task 3 evidence supplied for the consolidated report.

```
L$ ping -c 4 192.168.56.20
PING 192.168.56.20 (192.168.56.20) 56(84) bytes of data.
64 bytes from 192.168.56.20: icmp_seq=1 ttl=64 time=1.02 ms
64 bytes from 192.168.56.20: icmp_seq=2 ttl=64 time=1.51 ms
64 bytes from 192.168.56.20: icmp_seq=3 ttl=64 time=1.10 ms
64 bytes from 192.168.56.20: icmp_seq=4 ttl=64 time=1.34 ms

— 192.168.56.20 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3005ms
rtt min/avg/max/mdev = 1.016/1.239/1.505/0.193 ms
```

SS01 — Target Reachability

```

kali@kali:~$ sudo nmap -ss 192.168.56.20
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-11 07:39 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.20
Host is up (0.00098s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:FA:DD:2A (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.34 seconds

```

SS02 — TCP SYN Scan

5. Network Evidence — Service Detection & OS Detection

```
(kali@kali)-[~]
└─$ sudo nmap -sV 192.168.56.20
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-11 07:42 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.20
Host is up (0.0020s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:FA:DD:2A (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.01 seconds
```

SS03 — Service & Version Detection

```

kali@kali:~$ sudo nmap -O 192.168.56.20
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-11 07:48 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.20
Host is up (0.0015s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:FA:DD:2A (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.63 seconds

```

SS04 — OS Detection

5. Network Evidence — UDP & Consolidated Nmap

```
(kali@kali)-[~]
└─$ sudo nmap -sU --top-ports 100 192.168.56.20
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-11 08:20 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-
Nmap scan report for 192.168.56.20
Host is up (0.0012s latency).
Not shown: 50 closed udp ports (port-unreach), 46 open|filtered udp ports (no-response)
PORT      STATE SERVICE
53/udp    open  domain
111/udp   open  rpcbind
137/udp   open  netbios-ns
2049/udp  open  nfs
MAC Address: 00:0C:29:FA:DD:2A (VMware)

Nmap done: 1 IP address (1 host up) scanned in 48.52 seconds
```

SS05 — UDP Scan

```

(kali@kali)-[~]
$ sudo nmap -sS -sV -O 192.168.56.20 -oN task3-nmap.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-11 08:25 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.20
Host is up (0.0012s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh      OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet   Linux telnetd
25/tcp    open  smtp     Postfix smtpd
53/tcp    open  domain   ISC BIND 9.4.2
80/tcp    open  http     Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind  2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec     netkit-rsh rexecd
513/tcp   open  login    OpenBSD or Solaris rlogind
514/tcp   open  shell    Netkit rshd
1099/tcp  open  java-rmi  GNU Classpath grmiregistry
1524/tcp  open  bindshell Metasploitable root shell
2049/tcp  open  nfs      2-4 (RPC #100003)
2121/tcp  open  ftp      ProFTPD 1.3.1
3306/tcp  open  mysql    MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc      VNC (protocol 3.3)
6000/tcp  open  X11      (access denied)
6667/tcp  open  irc      UnrealIRCd
8009/tcp  open  ajp13    Apache Jserv (Protocol v1.3)
8180/tcp  open  http     Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:FA:DD:2A (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.76 seconds

(kali@kali)-[~]
$ cat task3-nmap.txt
# Nmap 7.99 scan initiated Fri Sep 11 08:25:46 2026 as: /usr/lib/nmap/nmap -sS -sV -O -oN task3-nmap.txt 192.168.56.20
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.20

```

SS06 — Consolidated Nmap Scan

5. Network Evidence — Wireshark Packet Analysis

Filter: ip.addr == 192.168.56.20 && tcp.flags.syn == 1

No.	Time	Source	Destination	Protocol	Length	Info
5	49.741233543	192.168.56.10	192.168.56.20	TCP	58	54271 → 53 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
6	49.741406898	192.168.56.10	192.168.56.20	TCP	58	54271 → 1723 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
7	49.741445282	192.168.56.10	192.168.56.20	TCP	58	54271 → 23 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
8	49.741498990	192.168.56.10	192.168.56.20	TCP	58	54271 → 443 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
9	49.741533660	192.168.56.10	192.168.56.20	TCP	58	54271 → 554 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
10	49.741571788	192.168.56.10	192.168.56.20	TCP	58	54271 → 139 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
11	49.741602741	192.168.56.10	192.168.56.20	TCP	58	54271 → 25 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
12	49.741634967	192.168.56.10	192.168.56.20	TCP	58	54271 → 445 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
13	49.741717772	192.168.56.10	192.168.56.20	TCP	58	54271 → 995 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
14	49.741749767	192.168.56.10	192.168.56.20	TCP	58	54271 → 1025 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
15	49.741905908	192.168.56.20	192.168.56.10	TCP	60	53 → 54271 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
18	49.742157606	192.168.56.20	192.168.56.10	TCP	60	23 → 54271 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
22	49.742662053	192.168.56.20	192.168.56.10	TCP	60	139 → 54271 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
23	49.742662248	192.168.56.20	192.168.56.10	TCP	60	25 → 54271 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
24	49.742662283	192.168.56.20	192.168.56.10	TCP	60	445 → 54271 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
30	49.743019506	192.168.56.10	192.168.56.20	TCP	58	54271 → 143 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
31	49.743101778	192.168.56.10	192.168.56.20	TCP	58	54271 → 21 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
32	49.743132793	192.168.56.10	192.168.56.20	TCP	58	54271 → 22 [SYN] Seq=0 Win=1024 Len=0 MSS=1460

Frame 5: Packet, 58 bytes on wire (464 bits), 58 bytes captured (464 bits) on interface eth0

Ethernet II, Src: VMware_65:45:89 (00:0c:29:65:45:89), Dst: VMware_fa:dd:2a (00:0c:29:fa:dd:2a)

Internet Protocol Version 4, Src: 192.168.56.10, Dst: 192.168.56.20

Transmission Control Protocol, Src Port: 54271, Dst Port: 53, Seq: 0, Len: 0

Source Port: 54271

Destination Port: 53

[Stream index: 0]

[Stream Packet Number: 1]

[Conversation completeness: Incomplete (35)]

[TCP Segment Len: 0]

Sequence Number: 0 (relative sequence number)

Sequence Number (raw): 713194843

[Next Sequence Number: 1 (relative sequence number)]

Acknowledgment Number: 0

Acknowledgment number (raw): 0

0110 = Header Length: 24 bytes (6)

Flags: 0x0002 (SYN)

Window: 1024

[Calculated window size: 1024]

Checksum: 0x26a5 (unverified)

SS07 — Wireshark TCP SYN Evidence

ip.addr == 192.168.56.20 && udp					
No.	Time	Source	Destination	Protocol	Length Info
1	0.000000000	192.168.56.20	192.168.56.255	BROWSER	286 Local Master Announcement METASPLOITABLE, Workstation, Server, Print Queue
2	0.000000214	192.168.56.20	192.168.56.255	BROWSER	257 Domain/Workgroup Announcement WORKGROUP, NT Workstation, Domain Enum
2032	469.552927207	192.168.56.10	192.168.56.20	UDP	84 53829 → 49152 Len=42
2033	469.553017978	192.168.56.10	192.168.56.20	UDP	82 53829 → 49152 Len=40
2034	469.553053931	192.168.56.10	192.168.56.20	UDP	42 53829 → 514 Len=0
2035	469.553074542	192.168.56.10	192.168.56.20	SSDP	136 M-SEARCH * HTTP/1.1
2036	469.553091649	192.168.56.10	192.168.56.20	UDP	42 53829 → 631 Len=0
2037	469.553109688	192.168.56.10	192.168.56.20	UDP	54 53829 → 135 Len=12
2038	469.553124980	192.168.56.10	192.168.56.20	UDP	114 53829 → 135 Len=72
2039	469.553142515	192.168.56.10	192.168.56.20	Portmap	82 V104316 proc-0 Call
2040	469.553173488	192.168.56.10	192.168.56.20	ISAKMP	56
2041	469.553192544	192.168.56.10	192.168.56.20	ISAKMP	234 Identity Protection (Main Mode)
2042	469.553207714	192.168.56.10	192.168.56.20	ISAKMP	246 Identity Protection (Main Mode)
2043	469.553228293	192.168.56.10	192.168.56.20	UDP	42 53829 → 1434 Len=0
2044	469.553264319	192.168.56.10	192.168.56.20	RIPv1	66 Request
2045	469.553282067	192.168.56.10	192.168.56.20	UDP	42 53829 → 445 Len=0
2046	469.553301228	192.168.56.10	192.168.56.20	UDP	42 53829 → 162 Len=0
2047	469.553984929	192.168.56.20	192.168.56.10	ICMP	112 Destination unreachable (Port unreachable)
2048	469.553985429	192.168.56.20	192.168.56.10	ICMP	112 Destination unreachable (Port unreachable)
Frame 2: Packet, 257 bytes on wire (2056 bits), 257 bytes captured (2056 bits) on interface Ethernet II, Src: VMware_fa:dd:2a (00:0c:29:fa:dd:2a), Dst: Broadcast (ff:ff:ff:ff:ff:ff) Internet Protocol Version 4, Src: 192.168.56.20, Dst: 192.168.56.255 User Datagram Protocol, Src Port: 138, Dst Port: 138 NetBIOS Datagram Service SMB (Server Message Block Protocol), Trans Request (0x25) SMB MailSlot Protocol * Microsoft Windows Browser Protocol Command: Domain/Workgroup Announcement (0x0c) Update Count: 4 Update Periodicity: 12 minutes Domain/Workgroup: WORKGROUP Windows version: OS Major Version: 4 OS Minor Version: 9 Server Type: 0x00001000, NT Workstation, Domain Enum Browser Protocol Major Version: 15 Browser Protocol Minor Version: 1 Signature: 0xaa55 Master Browser Server Name: METASPLOITABLE					
0000 ff ff ff ff ff ff 00 0c 29 fa dd 2a 00 00 45 00 0010 00 f3 00 00 40 00 40 11 47 96 c0 a8 38 14 c0 a8 0020 38 ff 00 8a 00 8a 00 df e6 53 11 0a 36 20 c0 a8 0030 38 14 00 8a 00 c9 00 00 20 45 4e 45 46 46 45 45 0040 42 46 44 46 41 45 4d 45 50 45 4a 46 45 45 42 45 0050 43 45 4d 45 46 43 41 41 41 00 20 41 42 41 43 46 0060 50 46 50 45 4e 46 44 45 43 46 43 45 50 46 48 46 0070 44 45 46 46 50 46 50 41 43 41 42 00 ff 53 4d 42 0080 25 00 00 00 00 00 00 00 00 00 00 00 00 00 00 0090 00 00 00 00 00 00 00 00 00 00 00 11 00 00 2f 00a0 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00b0 00 00 00 2f 00 56 00 03 00 01 00 01 00 02 00 00c0 00 5c 4d 41 49 4c 53 4c 4f 54 5c 42 52 4f 57 53 00d0 45 00 0c 04 80 fc 0a 00 57 4f 52 4b 47 52 4f 55 00e0 50 00 00 00 00 00 00 00 04 00 00 10 00 00 0f 01 00f0 55 aa 4d 45 54 41 53 50 4c 4f 49 54 41 42 4c 45 0100 00					
Packets: 2160 · Displayed: 129 (6.0%)					

SS08 — Wireshark UDP Evidence

6. Web Application Assessment — OWASP Juice Shop

Task 4 assessed a locally hosted OWASP Juice Shop instance in an authorized sandbox. Nmap was used for basic reconnaissance, while Burp Suite and the browser were used for HTTP traffic analysis, request modification and validation.

Evidence	Observation	Status
SS01	TCP/3000 open; HTTP response associated with Juice Shop	Demonstrated
SS02	Crafted login input produced HTTP 200 and authentication data	Demonstrated
SS03	Juice Shop displayed successful DOM XSS challenge completion	Demonstrated
SS05A	Original basket object retrieved as baseline	Baseline
SS05B	Changing object identifier returned another object's data	Demonstrated

Finding 1 — SQL Injection

The supplied Burp evidence shows a POST request to /rest/user/login where the email parameter contains SQL syntax. The server returned HTTP 200 and an authentication object. Potential impact includes authentication bypass, unauthorized data access or manipulation of database operations depending on the underlying query.

Remediation: use parameterized queries/prepared statements, server-side input validation and least-privilege database accounts.

Finding 2 — DOM-Based XSS

The Task 4 evidence demonstrates successful browser-side execution in the Juice Shop challenge. Remediation should include safe DOM APIs, contextual output encoding, elimination of unsafe HTML sinks and suitable browser security controls.

Finding 3 — BOLA/IDOR

The baseline-versus-modified-object evidence shows another object's data being returned after changing an object identifier. Enforce server-side authorization on every protected resource and verify ownership or explicit authorization for each requested object.

7. Web Findings — Risk & Remediation

Finding	Impact	Recommended Remediation	Priority
SQL Injection	Potential authentication bypass, unauthorized data access/manipulation	Parameterized queries; input validation; least-privilege DB account	P1
BOLA / IDOR	Exposure or modification of another user's data	Server-side object authorization; deny-by-default access control	P1
DOM XSS	Attacker-controlled script execution in victim browser context	Safe DOM APIs; output encoding; remove unsafe sinks	P2

Evidence Discipline

- Only supplied screenshots and documented behavior are treated as demonstrated proof.
- A service/version observation is not automatically a vulnerability.
- Potential impact is described separately from confirmed exploitation.
- No claim is made for stored XSS because the required successful evidence is absent.

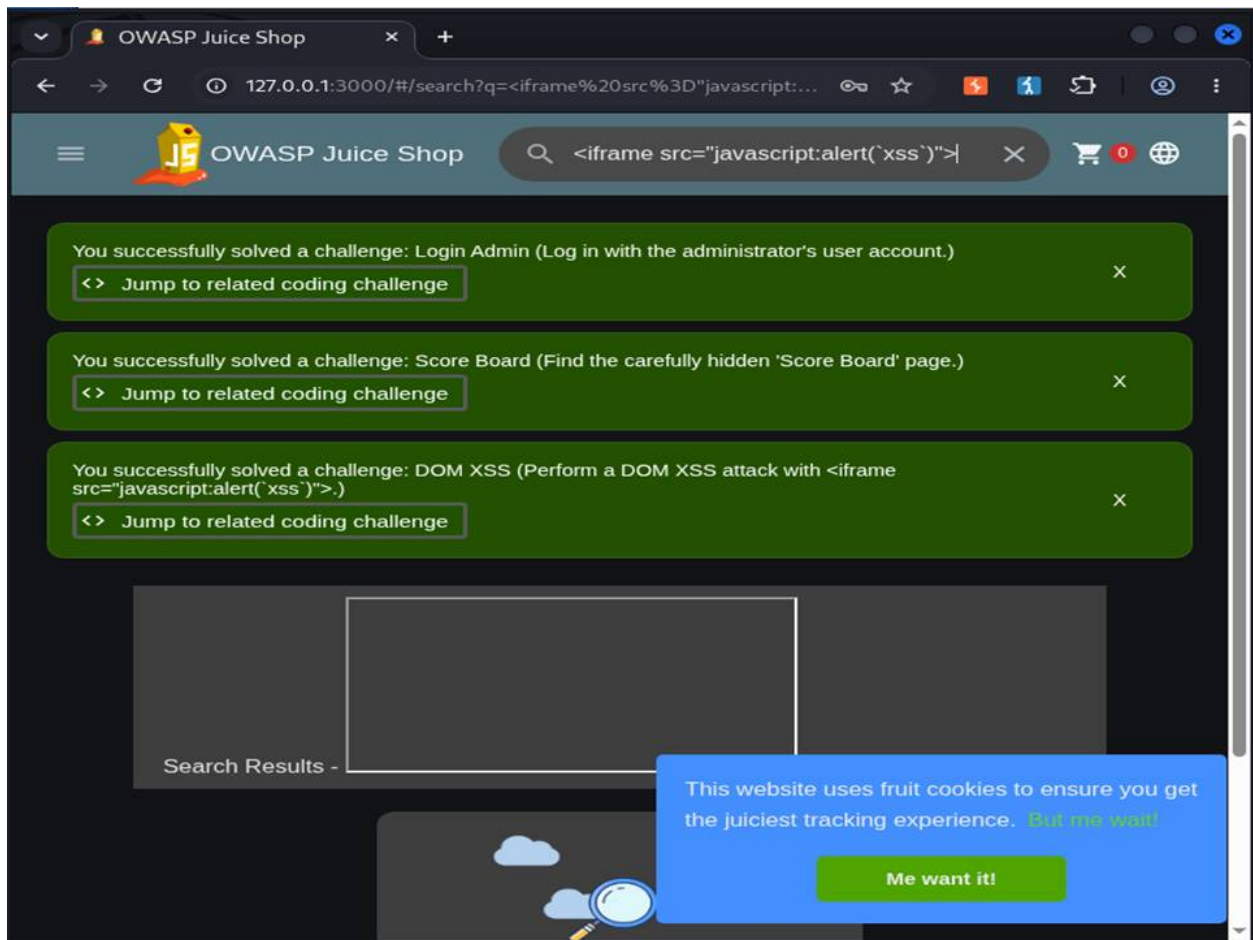
Developer Security Controls

- Use parameterized database operations wherever untrusted input reaches SQL.
- Perform authorization checks on the server for every object request.
- Treat client-controlled identifiers as untrusted.
- Validate and safely encode user-controlled data before DOM insertion.

8. Web Application Evidence — SQL Injection & DOM XSS

[illegible]

Task 4 — SQL Injection Burp Suite Evidence



Task 4 — DOM XSS Evidence

8. Web Application Evidence — BOLA / IDOR

Send
Cancel
Burp AI

Request

Pretty
Raw
Hex

```

1 GET /rest/basket/6 HTTP/1.1
2 Host: localhost:3000
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: application/json, text/plain, */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://localhost:3000/
8 Authorization: Bearer
  eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1Ni99.eyJkYXN0IjoiIiwiaXNja3RpdDkiOiJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1Ni99.eyJkYXN0IjoiIiwiaXNja3RpdDkiOiJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1Ni99
9 Connection: keep-alive
10 Cookie: language=en; welcomebanner_status=dismiss; continueCode=
  wqL2VP8MgeztNm04EQ37ABX17S88hmRLoG5Jxy9D9KYabpZX6Bnlw1; splunkweb_csrf_token_8000=
  17284611988307276853; cookieconsent_status=dismiss; token=
  eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1Ni99.eyJkYXN0IjoiIiwiaXNja3RpdDkiOiJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1Ni99.eyJkYXN0IjoiIiwiaXNja3RpdDkiOiJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1Ni99
11 If-None-Match: W/"9a-2fwmqdBNBFmKB1XEUM8CL3HX1/4"
12 Priority: u=4
13
14
```

Response

Pretty
Raw
Hex
Render

```

1 HTTP/1.1 200 OK
2 Access-Control-Allow-Origin: *
3 X-Content-Type-Options: nosniff
4 X-Frame-Options: SAMEORIGIN
5 Feature-Policy: payment 'self'
6 X-Recruiting: /#jobs
7 Content-Type: application/json; charset=utf-8
8 Content-Length: 562
9 ETag: W/"232-P2rbWfH9dZ20TaxXl41ID9c7vG0"
10 Vary: Accept-Encoding
11 Date: Fri, 18 Sep 2026 12:07:26 GMT
12 Connection: keep-alive
13 Keep-Alive: timeout=5
14
15 {
  "status": "success",
  "data": {
    "id": 6,
    "coupon": null,
    "userId": 25,
    "createdAt": "2026-09-18T12:05:59.414Z",
    "updatedAt": "2026-09-18T12:05:59.414Z",
    "Products": [
      {
        "id": 50,
        "name": "Dragonfruit Juice (500ml)",
        "description": "Exotic and vibrant juice made from dragon
        "price": 3.99,
        "deluxePrice": 3.99,
        "image": "dragonfruit_juice.png",
        "createdAt": "2026-09-18T11:52:42.800Z",
        "updatedAt": "2026-09-18T11:52:42.800Z",
        "deletedAt": null,
        "BasketItem": {
          "ProductId": 50,
          "BasketId": 6,

```

Search

0 highlights
Search

Task 4 — BOLA/IDOR Baseline Evidence

9. Preliminary CVSS 3.1 Assessment

The source Task 4 report used project-level High/Medium ratings rather than formal CVSS scores. The following values are preliminary analyst calculations for Task 6 based on the demonstrated behavior and should be reviewed by the training mentor.

Finding	Proposed CVSS 3.1 Vector	Score	Severity
SQL Injection	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	9.8	Critical
BOLA / IDOR	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N	8.1	High
DOM XSS	AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N	6.1	Medium

CVSS Caveats

- These scores are not directly present in Tasks 2–5.
- They are analyst-derived for this draft and may change if mentor review changes privilege, scope, user-interaction or impact assumptions.
- Do not describe these values as official vendor scores.

Risk Prioritization

Priority	Area	Action
P1	SQL Injection	Fix immediately; parameterized queries; retest authentication
P1	BOLA/IDOR	Fix immediately; enforce object-level authorization; retest cross-user access
P2	DOM XSS	Eliminate unsafe DOM sinks; retest with hostile input
P2	Exposed services	Disable unnecessary services; restrict ports; patch required services
P1	Scope reconciliation	Confirm LAB-02 address and update inventory if necessary

10. Cryptography & Secure Authentication Controls

Task 5 implemented three defensive security-control demonstrations in Node.js: AES-256-GCM authenticated encryption, RSA-2048 key generation and SHA-256 digital signatures, and bcrypt password hashing.

AES-256-GCM

The implementation generates a 32-byte key and 12-byte IV, encrypts a message, obtains an authentication tag, then decrypts and verifies the authenticated ciphertext. The recorded execution output demonstrates recovery of the original message.

RSA-2048

The implementation generates an RSA-2048 public/private key pair, signs data using SHA-256, and verifies the signature using the public key. The recorded output reports a valid signature.

bcrypt

The implementation hashes a password with a work factor of 12 and verifies the supplied password against the resulting hash without storing the plaintext password.

Security Recommendations

- Do not hard-code encryption keys or private keys in source code or repositories.
- Never reuse an AES-GCM IV with the same key.
- Never store plaintext passwords; use bcrypt with an appropriate work factor.
- Keep private RSA keys protected and expose only public keys where required.
- Exclude node_modules from Git while retaining package.json and package-lock.json.

11. Cryptography Evidence — Project Structure & AES-256-GCM

```
(kali㉿kali)-[~/task5-cryptography]
$ tree -L 2
.
├── aes.js
├── node_modules
│   ├── bcrypt
│   ├── node-addon-api
│   └── node-gyp-build
├── package.json
├── package-lock.json
├── password.js
├── README.md
└── rsa.js
```

Task 5 — Cryptography Project Structure

```
(kali@kali)-[~/task5-cryptography]
```

```
$ node aes.js
```

```
Encrypted: {
```

```
  iv: 'd1c62aeda989ea15f11df128',
```

```
  encrypted: '0499fdea22102cd568ec7bcb8107d3cd9685431219',
```

```
  authTag: '0592e81167b3a00dfc0c5c6af1cee5b3'
```

```
}
```

```
Decrypted: Hello RabTech Academy
```

Task 5 — AES-256-GCM Execution

11. Cryptography Evidence — RSA-2048 & bcrypt

```
(kali@kali)-[~/task5-cryptography]
```

```
$ node rsa.js
```

RSA-2048 key pair generated.

Signature: MZDHIDv6c+28huvKipbz86Co/rUsHq8aBBWGN4aVMV2BqKeu9WtUpoT
e4E2HzBYG0A8ec1kHOGcNmi2qephHE0/1R419LNwsEZhdGyNiefq0C768e+/eXqYSL

Signature valid: **true**

```
(kali@kali)-[~/task5-cryptography]
```

```
$
```

Task 5 — RSA-2048 Signature Verification

```
(kali@kali)-[~/task5-cryptography]
└─$ node password.js
Password hash:
$2b$12$f3Lg0Kpz3qbxHmJSyhz090xVeURNJ7STGhmRkyy10ZWrx05vHJ4yS
Password verified: true

(kali@kali)-[~/task5-cryptography]
└─$
```

Task 5 — bcrypt Password Hashing & Verification

12. Remediation Plan & Timelines

Finding / Area	Recommended Remediation	Suggested Timeline	Retest
SQL Injection	Parameterized queries; input validation; least-privilege DB account	0–3 days	Required
BOLA/IDOR	Server-side object authorization; deny-by-default policy	0–3 days	Required
DOM XSS	Safe DOM APIs; output encoding; remove unsafe sinks	3–7 days	Required
Exposed services	Disable unnecessary services; firewall segmentation; patch required services	7–14 days	Required
Cryptographic controls	Secret/key management; IV uniqueness; protected private keys	7–14 days	Recommended
Scope/IP mismatch	Confirm LAB-02 address with lab owner and update inventory	Before further testing	Required

Developer / Sysadmin Checklist

- Use parameterized database operations everywhere untrusted input reaches SQL.
- Perform authorization checks on the server for every object request.
- Treat client-controlled identifiers as untrusted.
- Validate and safely encode user-controlled data before DOM insertion.
- Disable legacy or unused network services and restrict exposure with firewall rules.
- Protect cryptographic keys and secrets outside source control.
- Repeat security testing after remediation and preserve evidence of retest results.

13. Evidence Register

This register separates evidence already demonstrated from items that remain conditional on mentor requirements.

Requirement	Current Evidence Status
Scope / authorization	Task 2 dossier available
Threat model	Task 2 STRIDE model available
Network reconnaissance	Task 3 Nmap/Wireshark evidence available
Web vulnerabilities	Task 4 SQLi, DOM XSS and BOLA/IDOR evidence available
Cryptographic implementation	Task 5 screenshots and code available
CVSS 3.1 scores	Preliminary Task 6 analyst calculation — mentor review
Formal remediation retest	
Final LAB-02 authorization/IP reconciliation	
Executive sign-off	

14. Conclusion

The completed RabTech Academy exercises provide a coherent foundation for a consolidated penetration-testing and vulnerability-assessment capstone. The work demonstrates controlled scope definition, threat modeling, network reconnaissance, web application testing, vulnerability validation, security-control implementation and evidence-based reporting. The strongest demonstrated application risks are SQL Injection, broken object-level authorization and DOM-based XSS. The reconnaissance exercise also shows a broad exposed service surface on the deliberately vulnerable VM, while Task 5 demonstrates practical defensive controls for authenticated encryption, digital signatures and password hashing. The most important remaining issue is evidence quality and final validation rather than additional random testing. The LAB-02 addressing history should be formally reconciled, and any claim that vulnerabilities have been remediated should be supported by post-fix retesting.

Prepared by PRITAM BOSE

15. References

- OWASP Foundation — OWASP Juice Shop documentation and companion resources.
- OWASP Foundation — OWASP Top 10 Web Application Security Risks.
- OWASP Foundation — Web Security Testing Guide (WSTG).
- PortSwigger — Burp Suite documentation.
- Nmap Project — Nmap Reference Guide.
- Kali Linux documentation — security testing and network tools.
- NIST SP 800-92 — Guide to Computer Security Log Management.
- MITRE ATT&CK — T1021 / T1021.004 references used in supporting lab material.
- RabTech Academy — Cybersecurity & Ethical Hacking Internship task instructions and Rules of Engagement.

Prepared by PRITAM BOSE